DESIGN AND APPLY CONTEXT-AWARE ACCESS CONTROLS BASED ON USER IDENTITY, DEVICE POSTURE, LOCATION, AND APPLICATION RISK.

Project Title:

Design and apply context-aware access controls based on user identity, device posture, location, and application risk.

Program: Naan Mudhalvan

Course : Cyber Security

Team Members:

Member 1 – Mythili P & mythilipalanisamy2203@gmail.com

Member 2 – Pooja sri J & jawaharlalpooja23@gmail.com

Member 3 –Poovarasan M & poovupoovu905@gmail.com

Member 4 –Sriramkumar S & sriramkumar14356@gmail.com

Member 5 –Subash S & subashguna71@gmail.com

Institution : SMS College of Arts and Science

Guide : K.PRIYADHARSHINI.,MSc., Mphil.,

Date :15.03.2026

Abstract:

With the rapid growth of cloud services, mobile devices, and remote work environments, organizations face significant challenges in protecting sensitive applications and data while maintaining convenient user access. Traditional security models that rely mainly on network-based controls often fail to provide sufficient protection because they grant broad access once a user is inside the network. This increases the risk of unauthorized access, insider threats, and potential data breaches. To overcome these limitations, modern security strategies implement context-aware access control mechanisms that evaluate multiple factors before granting access to enterprise resources.

This project focuses on designing and implementing context-aware access controls that consider user identity, device posture, location, and application risk levels to ensure secure and adaptive access management. Instead of providing uniform access to all users, the system dynamically evaluates contextual information to determine whether a user should be granted, restricted, or denied access. By verifying the identity of the user, assessing the security posture of the device, analyzing the geographical location, and evaluating the sensitivity of the requested application, the system can enforce intelligent access policies that reduce security risks.

The architecture integrates identity management systems, device security checks, and policy enforcement mechanisms to create a secure access environment. Context-aware policies are configured to allow access only when predefined security conditions are satisfied. For example, users may be allowed to access critical applications only from trusted devices or approved locations, while high-risk scenarios trigger additional authentication or access restrictions. This approach improves security visibility and enables organizations to implement least-privilege access to sensitive applications.

The implementation demonstrates how context-aware access control enhances enterprise security by continuously evaluating access conditions and adapting policies accordingly. Key features of the system include dynamic policy enforcement, risk-based authentication, device compliance verification, and location-based access restrictions. Testing results show that this approach significantly reduces unauthorized access attempts while maintaining smooth and efficient access for legitimate users.

In conclusion, the project highlights the importance of context-aware security models in modern enterprise environments. By designing and applying intelligent access control policies based on identity, device posture, location, and application risk, organizations can strengthen their security posture, protect sensitive resources, and support secure access for users in distributed and remote work environments.

Use Case Scenarios

Scenario 1: Finance Department Access to ERP System

A senior accountant in the finance department needs to access the corporate Enterprise Resource Planning (ERP) system to process monthly payroll. The user connects from a remote location using their company-managed laptop. Upon launching the ZPA Client Connector, they authenticate via Azure Active Directory with multi-factor authentication (MFA). ZPA evaluates the user's identity, group membership (Finance_ERP_Users), device posture (antivirus active, disk encryption enabled), and connection context. The policy engine determines that the user is authorized and brokers a secure, direct micro-tunnel to the ERP application only. The user can interact with the ERP interface, but has no visibility or network-level access to any other internal systems, such as development servers or the HR database.

Output:

● User authenticated and authorized based on identity and group membership

● Direct micro-tunnel established specifically to the ERP application

Scenario 2: Contractor Access to Specific Project Repository

An external software consultant is hired for a three-month project and requires access only to a specific Git repository hosted on an internal server. The contractor is onboarded as a guest user in the identity provider and assigned to the "Project_X_Contractors" group. When the contractor connects using the ZPA client, the system verifies their identity and checks the device for basic security compliance (OS patch level, firewall enabled). ZPA enforces a policy that grants access exclusively to the Git repository application (port 22/SSH or port 443/HTTPS) during business hours (9 AM to 5 PM). The contractor can clone, push, and pull code, but cannot discover or connect to any other internal resources, including the corporate intranet or file servers.

Output:

● Time-bound and role-specific access enforced

● Lateral movement to adjacent systems completely blocked

Scenario 3: Executive Access to Sensitive Financial Documents

A company VP needs to access a folder containing confidential M&A documents stored in a corporate SharePoint site. The user connects from a hotel business center while traveling internationally, using their company-managed tablet. Upon launching the ZPA Client Connector, they authenticate via Azure Active Directory with MFA. ZPA evaluates the user's identity, executive group membership, and device posture (which is compliant). However, the geolocation (unusual foreign country) and the application risk (highly sensitive document repository) trigger an elevated risk score. The policy engine grants access to the SharePoint site, but enforces additional restrictions:

download and print capabilities are disabled, and the session is monitored for unusual behavior (e.g., mass download attempts). An alert is also sent to the security team for high-risk executive login.

Output:

● User authenticated with MFA and device compliant, but flagged for unusual location

● Read-only access granted with download/print restrictions enforced

● Security team alerted to potential credential misuse or espionage attempt

Scenario 4: Remote Support Technician Access to Internal Tools

An IT support technician needs to access the corporate ServiceNow instance and a remote desktop tool to assist an employee. The technician connects from their home office using a company-managed desktop. Upon launching the ZPA Client Connector, they authenticate via Azure Active Directory with MFA. ZPA evaluates the user's identity, group membership (IT_Support), device posture (fully compliant), and connection type (home office, which is whitelisted for IT staff). Because the user, device, and location all meet the baseline, the policy engine grants direct micro-tunnel access to both ServiceNow and the specific remote desktop jump host used for employee support. The technician can perform their duties efficiently, but still has no access to finance systems, HR databases, or source code repositories.

Output:

● User authenticated and fully authorized based on trusted context

● Direct micro-tunnels established to ServiceNow and the remote desktop jump host

● Least-privilege access maintained; unrelated internal systems remain invisible

Scenario 5: High-Risk Application Access from a Low-Trust Location

A marketing coordinator needs to access the corporate Salesforce instance to update a campaign. The user connects from a coffee shop using their company-managed smartphone. Upon launching the ZPA Client Connector, they authenticate via Azure Active Directory with MFA. ZPA evaluates the user's identity, group membership (Marketing_Salesforce_Users), device posture (managed and compliant), but flags the public Wi-Fi network as a high-risk connection. The policy engine determines that while the user and device are trusted, the network environment introduces unacceptable risk for direct access to a customer-facing CRM containing sensitive lead data. Instead of blocking access entirely, the user is routed through a secure ZPA browser isolation service, rendering the Salesforce session in a disposable container that prevents any data from persisting on the device or being exposed to the public network..

Output:

● User authenticated and device compliant, but network location deemed high-risk

● Access granted via browser isolation to prevent data leakage on public Wi-Fi

STAGE – 1

Title of the project :

Design and apply context-aware access controls based on user identity, device posture, location, and application risk.

List of vulnerability :

S.no	Vulnerability Name	CWE/CVE - No
1	Absolute Path Traversal	CWE-36
2	ASP.NET Misconfiguration: Password in Configuration File	CWE-13
3	Use of Unmaintained Third Party Components	CWE-1104
4	Cleartext Transmission of Sensitive Information	CWE-319
5	Improper Neutralization of Equivalent Special Elements	CWE-76
6	Plaintext Storage of a Password	CWE-256
7	Improper Authentication	CWE-287
8	Untrusted Search Path	CWE-426
9	Omission of Security-relevant Information	CWE-223
10	Unchecked Return Value	CWE-252

List of teammates

S.no	name	collage	contact
1.	Mythili P	SMS College of Arts & Science	8248088642
2.	Pooja sri J	SMS College of Arts & Science	83000 61160
3.	Sriramkumar S	SMS College of Arts & Science	8072 927 531
4.	Poovarasan M	SMS College of Arts & Science	95858 09028
5.	Subash S	SMS College of Arts & Science	82203 73755

REPORT:

Vulnerability Name:- Absolute Path Traversal

CWE/CVE : -CWE-36

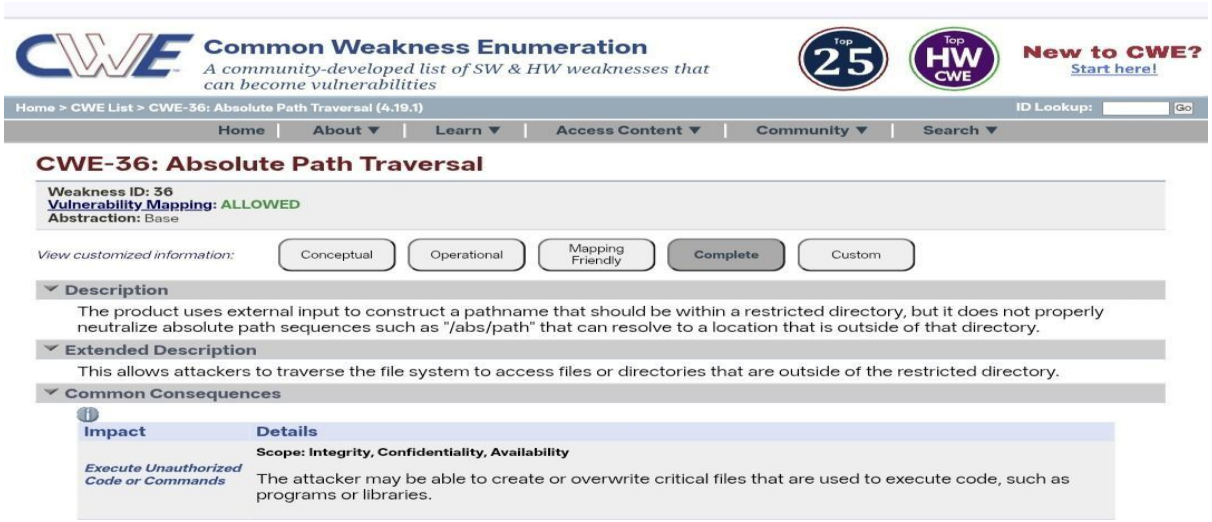
OWASP/SANS Category:-A01:2025 Broken Access Control

Description:-

Absolute Path Traversal is a vulnerability that allows attackers to access files and directories outside the intended folder of a web application. This occurs when user input used in file paths is not properly validated. By manipulating the file path, an attacker can access sensitive files such as system configurations, application code, or confidential data. Proper input validation and restricting file access can help prevent this vulnerability.

Business Impact::-

Absolute Path Traversal can have serious consequences for an organization. If exploited, attackers may gain unauthorized access to sensitive files such as system configurations, application source code, or confidential business data. This can lead to data breaches, exposure of internal information, system compromise, and loss of customer trust. In severe cases, it may also result in financial losses, legal penalties, and damage to the organization’s reputation. Proper security controls and input validation are necessary to reduce this risk.



Vulnerability Name:- ASP.NET Misconfiguration: Password in Configuration Fil**e CWE/CVE :** CWE-13

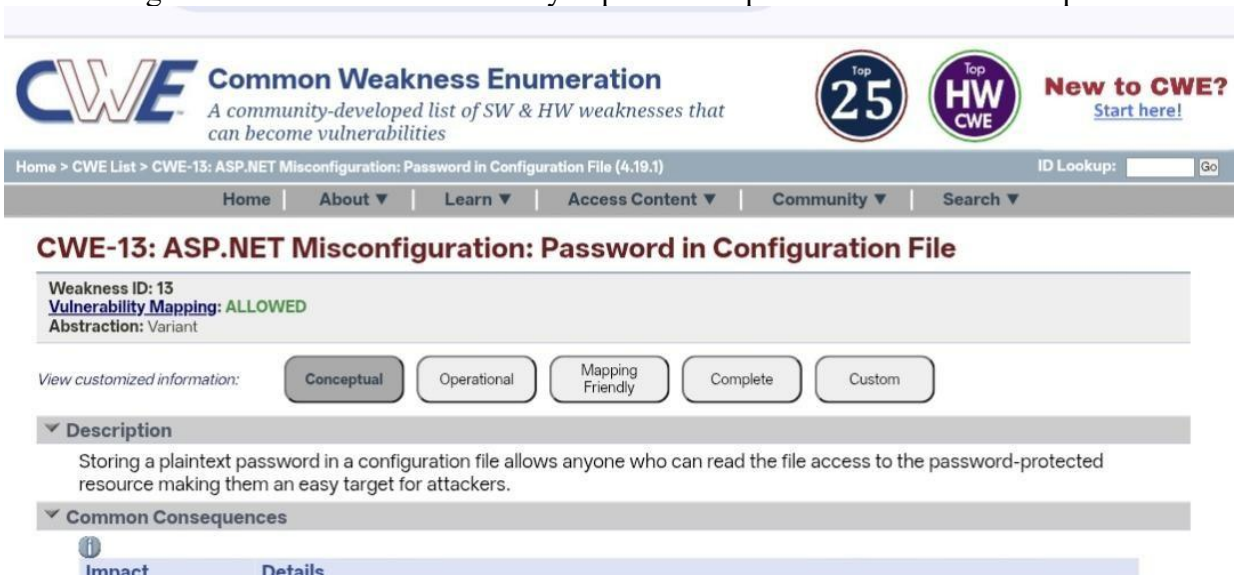
OWASP/SANS Category: A02:2025 - Security Misconfiguration

Description:-

This vulnerability occurs when sensitive information such as passwords, database credentials, or API keys are stored in plain text within ASP.NET configuration files (e.g., web.config). If these configuration files are not properly secured, attackers may gain access to them through misconfigured servers, source code exposure, or unauthorized file access. Once obtained, these credentials can be used to access databases, internal systems, or other critical services

Business Impact:

Exposure of passwords in configuration files can lead to unauthorized access to critical systems and sensitive organizational data. Attackers may exploit the exposed credentials to compromise



databases, manipulate application data, or gain deeper access to the internal network. This can result in data breaches, financial losses, service disruption, legal consequences, and significant damage to the organization's reputation and customer trust.

Vulnerability Name:-Use of Unmaintained Third Party Components

CWE/CVE : CWE-1104

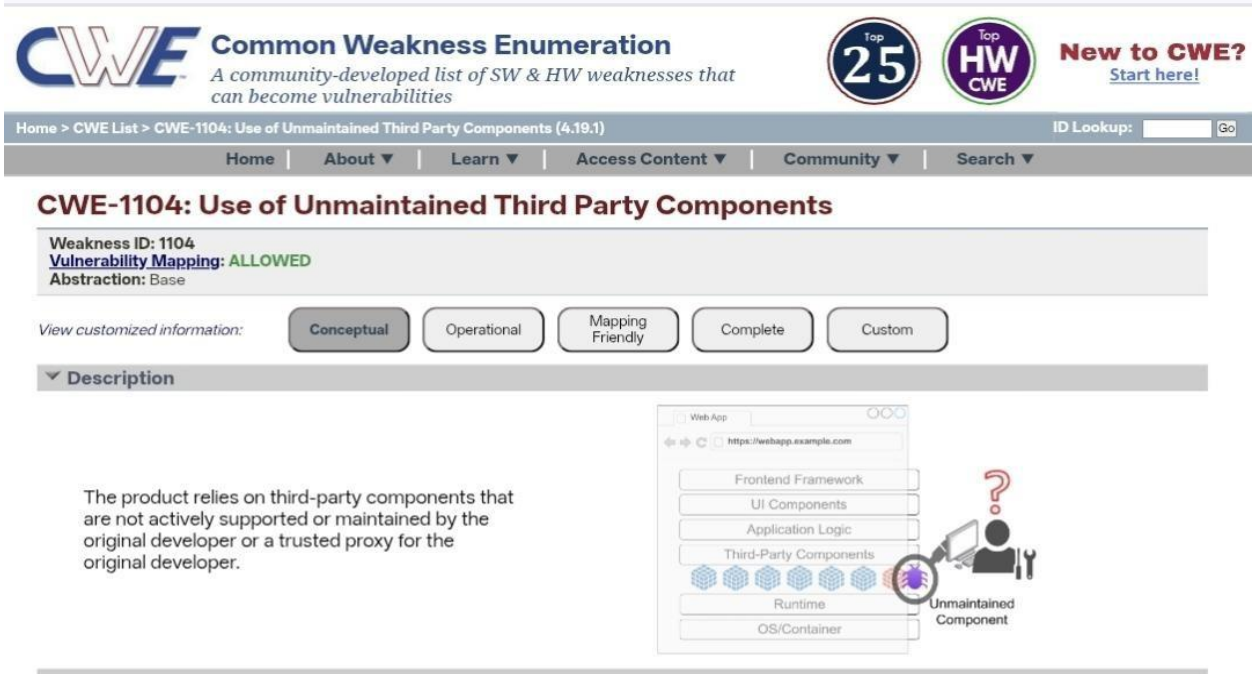
OWASP/SANS Category: A03:2025 - Software Supply Chain Failures

Description:-

This vulnerability occurs when an application uses third-party libraries, frameworks, or software components that are no longer maintained or updated by their developers. Unmaintained components may contain known security vulnerabilities that remain unpatched, making them an easy target for attackers. Since these components do not receive security updates or fixes, any existing weaknesses can be exploited to compromise the application.

Business Impact:

Using unmaintained third-party components can expose the application to serious security risks, including unauthorized access, data breaches, and system compromise. Attackers may exploit known vulnerabilities in outdated components to gain control of the system or access sensitive data. This can lead to financial losses, operational disruptions, legal issues, and damage to the organization's reputation and customer trust.



Vulnerability Name:- Cleartext Transmission of Sensitive Information

CWE/CVE : CWE-319

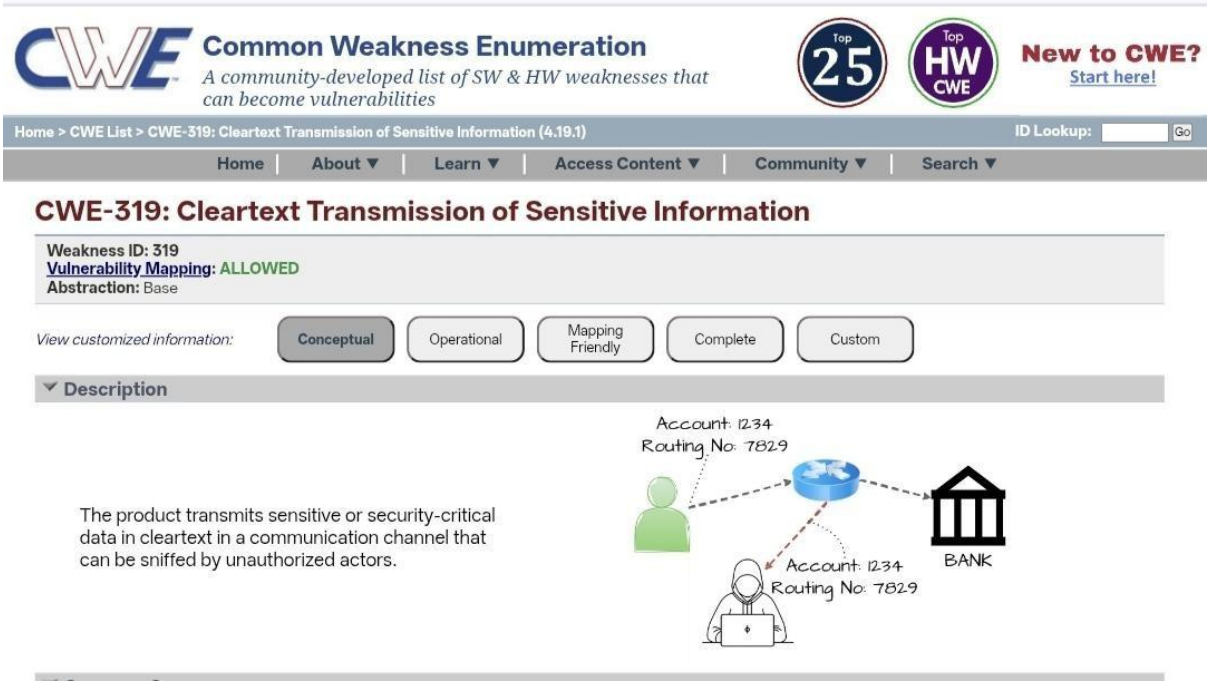
OWASP/SANS Category: A04:2025 - Cryptographic Failures

Description:-

This vulnerability occurs when sensitive information such as usernames, passwords, personal data, or financial details is transmitted over a network without encryption. When data is sent in cleartext, attackers can intercept and read the information using techniques such as network sniffing or man-in-the-middle attacks. This usually happens when secure communication protocols like HTTPS or encryption mechanisms are not properly implemented.

Business Impact:

Cleartext transmission of sensitive information can lead to unauthorized access to confidential data, account compromise, and data breaches. Attackers who intercept this information may misuse it for identity theft, financial fraud, or further system attacks. This can result in financial loss, legal penalties, regulatory violations, and significant damage to the organization's reputation and customer trust.



Vulnerability Name:-Improper Neutralization of Equivalent Special Elements

CWE/CVE : CWE-76

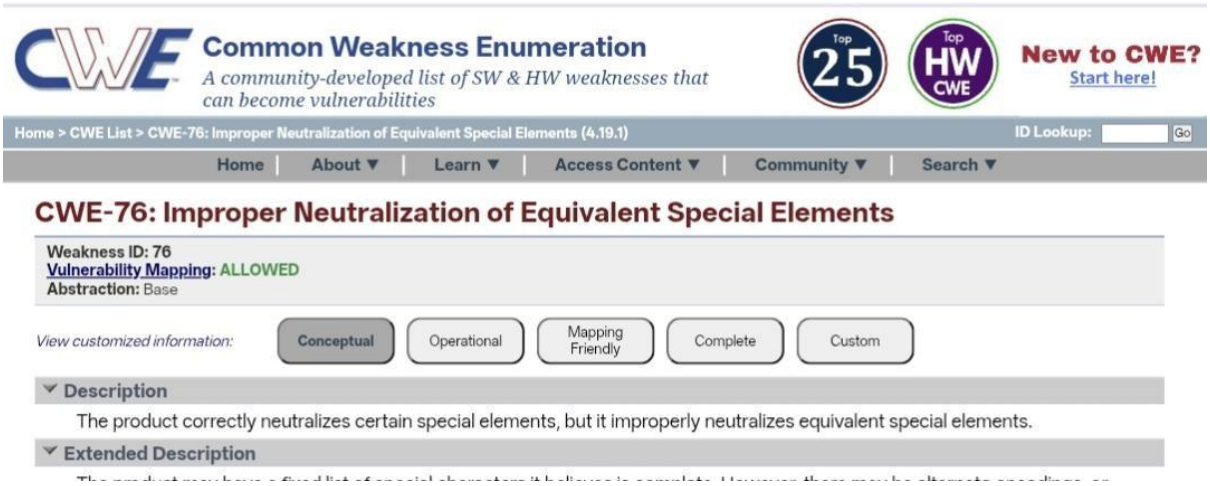
OWASP/SANS Category: A05:2025 – Injection

Description:-

This vulnerability occurs when a web application fails to properly validate or sanitize special characters or elements in user input. Attackers can exploit this weakness by inserting malicious code or unexpected input that the system interprets differently, leading to security issues such as injection attacks or unauthorized actions. Improper neutralization allows attackers to bypass security controls and manipulate the application's behavior.

Business Impact:

If exploited, this vulnerability can allow attackers to access sensitive information, modify application data, or execute unauthorized commands within the system. This may lead to data breaches, service disruption, and compromise of critical systems. As a result, organizations may experience financial losses, regulatory penalties, and damage to their reputation and customer trust.



Vulnerability Name:-Plaintext Storage of a Password

CWE/CVE : CWE-256

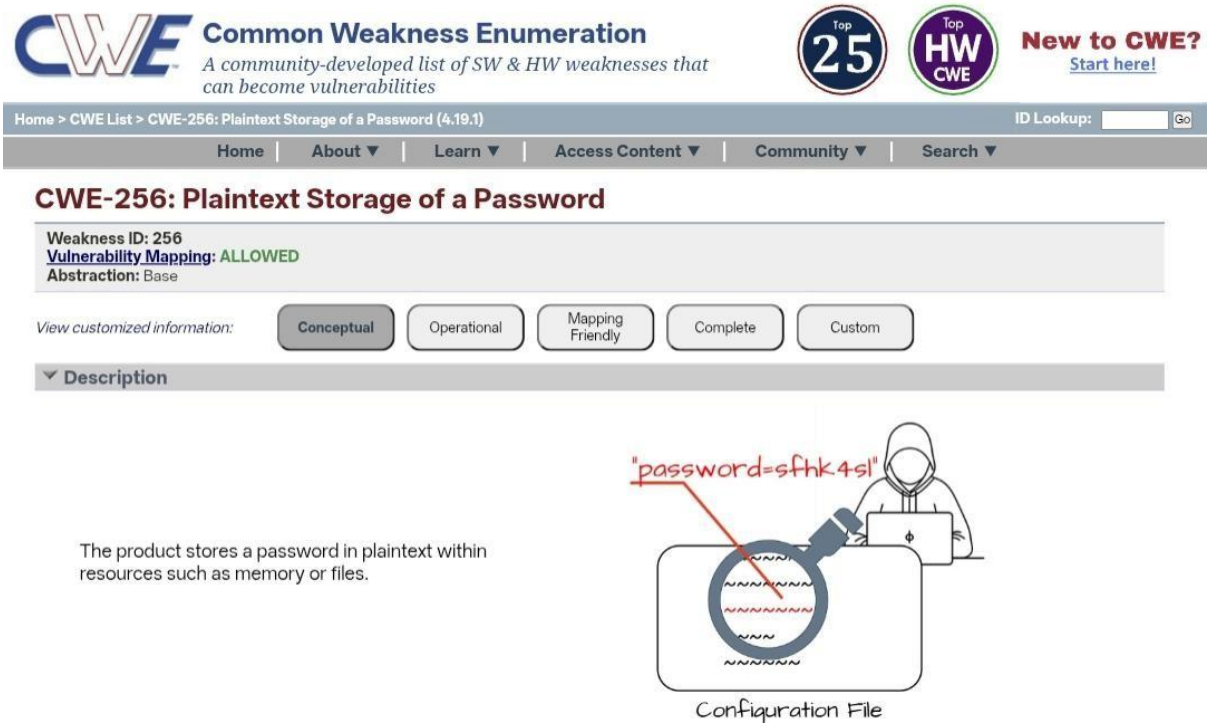
OWASP/SANS Category: A06:2025 - Insecure Design

Description:-

This vulnerability occurs when an application does not properly filter or handle special characters or encoded inputs provided by users. Attackers may use alternate representations (such as encoded or equivalent special elements) to bypass security filters and inject malicious input into the system. This weakness can allow attackers to manipulate application behavior, access restricted data, or perform unauthorized actions.

Business Impact:

Exploitation of this vulnerability can lead to unauthorized access to sensitive information, data manipulation, or execution of malicious commands within the application. This may result in data breaches, disruption of services, financial losses, and damage to the organization's reputation. Proper input validation and secure coding practices are essential to reduce this risk**.**



Vulnerability Name:- Omission of Security-relevant Information

CWE/CVE : CWE-223

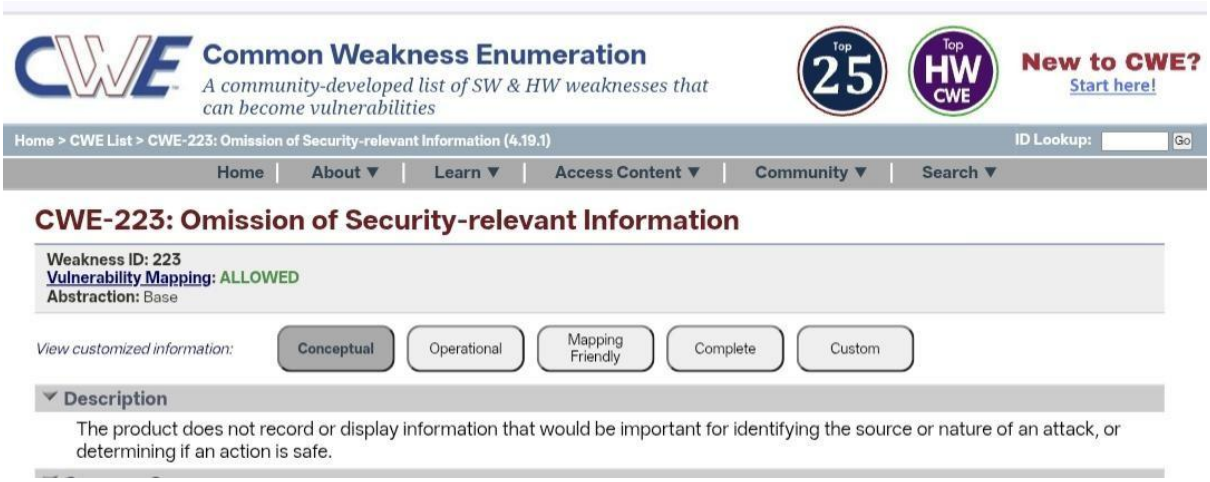
OWASP/SANS Category: A09:2025 - Security Logging and Alerting Failures

Description:-

Omission of Security-Relevant Information occurs when an application fails to record or provide important security-related details such as login attempts, access requests, errors, or suspicious activities. Without proper logging and monitoring, it becomes difficult to detect security incidents, investigate attacks, or respond to potential threats in a timely manner.

Business Impact:

If security-relevant information is not properly logged or monitored, organizations may be unable to identify unauthorized access, data breaches, or malicious activities within their systems. This can delay incident response, increase the impact of cyberattacks, and result in financial losses, regulatory penalties, and damage to the organization's reputation. Proper logging and monitoring practices are essential to maintain strong security visibility.



Vulnerability Name:-Unchecked Return Value

CWE/CVE : CWE-252

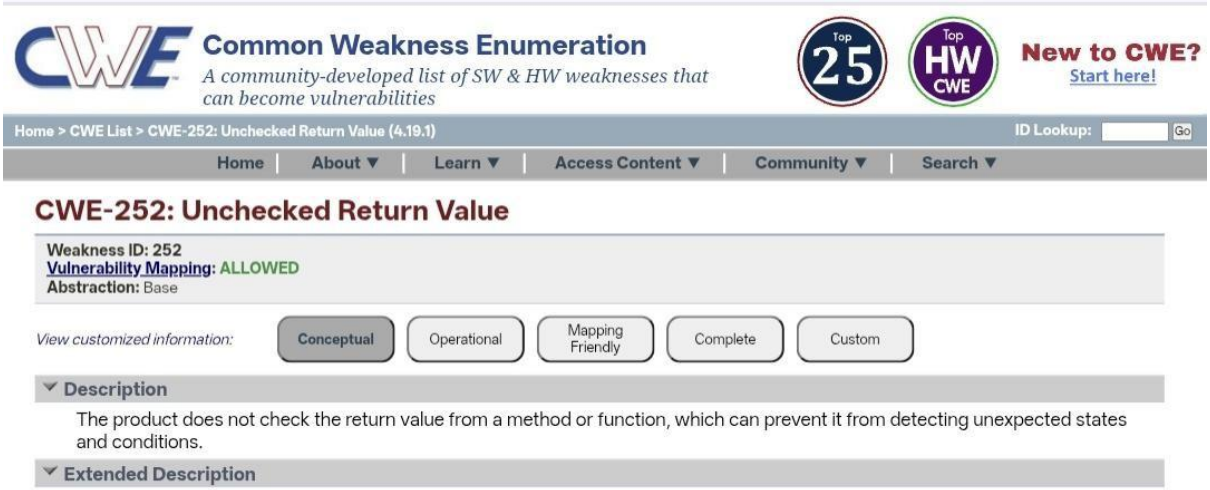
OWASP/SANS Category: A10:2025 - Mishandling of Exceptional Conditions

Description:-

Unchecked Return Value is a vulnerability that occurs when a program fails to verify the return value of a function or system call. Many functions return a value indicating whether an operation was successful or failed. If the application does not check these return values, it may continue execution even when an error has occurred. This can lead to unexpected behavior, security weaknesses, or system failures.

Business Impact:

Exploiting this vulnerability may allow attackers to trigger application errors, bypass security controls, or cause system instability. This can lead to data corruption, service disruptions, or unauthorized actions within the system. As a result, organizations may face operational issues, financial losses, and potential damage to their reputation.



STAGE 2

Nessus is a popular vulnerability assessment tool developed by Tenable. It is widely used by security professionals to identify vulnerabilities, configuration issues, and security weaknesses in systems, networks, and applications. Nessus helps organizations detect potential threats before attackers can exploit them, thereby improving overall cybersecurity.

Nessus works by scanning computers, servers, network devices, and applications to identify known vulnerabilities using a regularly updated vulnerability database. The tool checks for security issues such as outdated software, missing security patches, weak configurations, and exposed services. After the scanning process is completed, Nessus generates detailed reports that classify vulnerabilities based on their severity levels such as **Low, Medium, High, and Critical**.

One of the major advantages of Nessus is its ability to perform **comprehensive vulnerability scanning** across different platforms including operating systems, databases, and web applications. It also supports **configuration auditing**, which helps organizations verify whether systems follow recommended security standards and best practices.

Additionally, Nessus provides features such as **risk prioritization, vulnerability management, compliance checks, and detailed security reports**. These features allow security teams to quickly identify the most critical vulnerabilities and apply appropriate mitigation measures. By regularly performing vulnerability scans, organizations can strengthen their security posture and reduce the risk of cyber attacks.

In conclusion, Nessus plays an important role in vulnerability management by helping organizations detect, analyze, and remediate security weaknesses in their IT infrastructure. Its powerful scanning capabilities and detailed reporting make it a valuable tool for maintaining secure and reliable systems.

- **Vulnerability Scanning:** Detects known security vulnerabilities in systems and applications.
- **Configuration Auditing:** Identifies insecure configurations in operating systems and network devices.
- **Compliance Checking:** Helps organizations verify compliance with security standards.
- **Detailed Reports:** Provides risk severity levels such as **Low, Medium, High, and Critical**.
- **Continuous Updates:** Regularly updated vulnerability database to detect new threats.

List of Vulnerabilities:

S.No	Vulnerability Name	Severity	Plugin / Tool
1	Cross-Site Scripting (Stored)	Low	Web Application Scanner
2	Broken Access Control	Medium	SSH Weak HMAC Algorithms Supported
3	SQL Injection	Medium	N/A
4	Broken Authentication	Low	HSTS Missing from Server
5	Insecure Direct Object Reference (IDOR)	Info	Service Detection
6	Security Misconfiguration	Low	SSL Cipher Block Chaining Cipher Suites
7	Cross-Site Request Forgery (CSRF)	Low	HTTP Form-Based Authentication Detected
8	Cleartext Transmission of Sensitive Information	Medium	Cleartext Transmission over HTTP

Target Website: testfire.net

Target IP Address: 54.83.41.36

Vulnerability name Severity level (Low, Medium, High, Critical)

Plugin ID Description of the issue Recommended solution

1. Vulnerability Name: Cross-Site Scripting (Stored)

Severity: Low
Plugin: Web Application Scanner
Port: 80 / 443

Description:
Stored XSS occurs when malicious scripts are permanently stored in a web application and executed in users' browsers.

Solution:
Validate and sanitize user inputs and implement secure coding practices.

2. Vulnerability Name: Broken Access Control

Severity: Medium
Plugin: SSH Weak HMAC Algorithms Supported
Port: 22

Description:
Improper access control allows unauthorized users to access restricted resources.

Solution:
Implement strong access control policies and role-based access control (RBAC).

3. Vulnerability Name: SQL Injection

Severity: Medium
Plugin: N/A
Port: 80 / 443

Description:
SQL Injection occurs when user input is not properly validated and is used in database queries.

Solution:
Use parameterized queries, input validation, and prepared statements.

4. Vulnerability Name: Broken Authentication

Severity: Low
Plugin: HSTS Missing from Server
Port: 443

Description:
Weak authentication mechanisms may allow attackers to bypass login controls.

Solution:
Implement strong authentication mechanisms and enable HTTPS with HSTS.

5. Vulnerability Name: Insecure Direct Object Reference (IDOR)

Severity: Info
Plugin: Service Detection
Port: 80 / 443

Description:
Attackers can access unauthorized data by modifying object identifiers in URLs.

Solution:
Implement proper authorization checks for every request.

6. Vulnerability Name: Security Misconfiguration

Severity: Low
Plugin: SSL Cipher Block Chaining Cipher Suites
Port: 443

Description:
Improper server configuration may expose applications to security risks.

Solution:
Disable weak SSL/TLS ciphers and follow secure configuration standards.

7. Vulnerability Name: Cross-Site Request Forgery (CSRF)

Severity: Low
Plugin: HTTP Form-Based Authentication Detected
Port: 80 / 443

Description:
CSRF attacks trick authenticated users into performing unwanted actions.

Solution:
Use CSRF tokens and implement proper request validation.

8. Vulnerability Name: Cleartext Transmission of Sensitive Information

Severity: Medium
Plugin: Cleartext Transmission over HTTP
Port: 80

Description:
Sensitive data transmitted over HTTP can be intercepted by attackers.

Solution:
Use HTTPS encryption and disable insecure HTTP communication.

STAGE 3

REPORT:

Title: Design and apply context-aware access controls based on user identity, device posture, location, and application risk.

Ability of SOC / SIEM

A **Security Operations Center (SOC)** and **Security Information and Event Management (SIEM)** system play an important role in maintaining the security of enterprise networks and applications. They help organizations continuously monitor, detect, analyze, and respond to security threats in real time.

A **SOC** is a centralized team responsible for monitoring the security of an organization's IT infrastructure. The SOC team analyzes security alerts, investigates suspicious activities, and responds to potential cyber threats. They work 24/7 to ensure that any abnormal behavior or attack attempt is quickly identified and handled.

A **SIEM system** collects and analyzes security logs from various sources such as servers, applications, network devices, and user systems. It aggregates this data into a centralized platform where security analysts can detect unusual patterns, unauthorized access attempts, and potential vulnerabilities. SIEM tools also provide automated alerts when suspicious activities are detected.

One of the main abilities of SOC/SIEM is **real-time monitoring and threat detection**. By continuously analyzing log data and security events, the system can quickly identify potential attacks such as unauthorized access, malware activity, or unusual login behavior. This helps organizations respond to threats before they cause serious damage.

Another important capability is **incident investigation and response**. When a security alert is generated, SOC analysts use SIEM dashboards and logs to analyze the event, determine its severity, and take appropriate actions such as blocking the attacker, isolating affected systems, or strengthening security controls.

SOC/SIEM systems also provide **security visibility and compliance support**. They maintain detailed records of system activities, which helps organizations meet regulatory and compliance requirements. These logs can be used for auditing, forensic analysis, and improving overall security strategies.

In conclusion, SOC and SIEM provide centralized monitoring, threat detection, incident response, and security analysis capabilities. By using these systems, organizations can strengthen their cybersecurity posture, detect threats early, and ensure the protection of critical enterprise applications and

SOC (Security Operations Center)

A **Security Operations Center (SOC)** is a centralized unit responsible for monitoring, detecting, analyzing, and responding to cybersecurity threats within an organization. The SOC team continuously monitors network traffic, system logs, and security alerts to identify suspicious activities. Security analysts working in the SOC investigate incidents, respond to attacks, and ensure that the organization's systems and data remain secure. SOC plays an important role in protecting enterprise networks, applications, and user data from cyber threats by providing 24/7 security monitoring and rapid incident response.

SOC Cycle

The **SOC cycle** describes the continuous process followed by a Security Operations Center to manage security incidents. It usually starts with **monitoring**, where security tools collect logs and events from different systems. The next stage is **detection**, where analysts identify unusual activities or potential threats. After detection, the SOC team performs **analysis and investigation** to understand the nature and impact of the threat. The next step is **response and mitigation**, where the team takes action to stop the attack and reduce damage. Finally, the **review and improvement** stage helps strengthen security controls to prevent similar incidents in the future.

SIEM (Security Information and Event Management)

Security Information and Event Management (SIEM) is a security solution that collects, analyzes, and manages security data from various sources such as servers, applications, network devices, and user systems. SIEM tools aggregate log data into a centralized platform where security analysts can monitor and analyze events in real time. By correlating different security events, SIEM helps detect suspicious activities, unauthorized access attempts, and potential security breaches. It also generates alerts and reports that assist organizations in responding to incidents quickly and maintaining compliance with security standards.

SIEM Cycle

The **SIEM cycle** involves several stages that help organizations manage security events effectively. The first stage is **data collection**, where logs and security events are gathered from different systems and devices. The next stage is **normalization and correlation**, where

the collected data is organized and analyzed to identify patterns or suspicious activities. The third stage is **alert generation**, where the system notifies security teams about potential threats. The final stage is **incident response and reporting**, where security analysts investigate alerts, respond to incidents, and generate reports to improve the organization's security posture.

MISP (Malware Information Sharing Platform)

Malware Information Sharing Platform (MISP) is an open-source threat intelligence platform used to share cybersecurity information between organizations. It helps security teams exchange data about malware, cyber threats, vulnerabilities, and attack indicators. By sharing threat intelligence, organizations can detect and respond to cyber threats more effectively. MISP supports collaboration between security teams, researchers, and organizations to improve global cybersecurity awareness. It also helps SOC teams identify new threats quickly and strengthen their defense mechanisms.

Your College Network Information

The **college network infrastructure** connects various systems and devices such as computer laboratories, administrative offices, faculty departments, and student networks. The network usually includes routers, switches, servers, wireless access points, and internet gateways that allow users to access online resources and institutional applications. Security measures such as firewalls, antivirus software, and user authentication are implemented to protect the network from unauthorized access and cyber threats. Monitoring tools and access control policies help ensure that only authorized users can access sensitive academic or administrative systems, maintaining the security and reliability of the college network.

How You Think You Deploy SOC in Your College (Extended)

To deploy a **Security Operations Center (SOC)** in our college, the first step is to establish a centralized monitoring system that collects security data from different parts of the campus network. This includes servers, routers, switches, firewall devices, Wi-Fi networks, and computer lab systems. All logs generated by these devices will be forwarded to a centralized SIEM platform where they can be analyzed in real time.

The SOC team would monitor the alerts generated by the SIEM tool and investigate any suspicious activities such as multiple failed login attempts, unusual data transfers, or malware detection. Security policies such as user authentication, access control, and network

segmentation would also be implemented to protect sensitive systems like student records, examination databases, and administrative portals. By implementing SOC in the college environment, the institution can continuously monitor network security and respond quickly to cyber threats.

Threat Intelligence (Extended)

Threat intelligence plays a critical role in improving cybersecurity defenses by providing information about current and emerging cyber threats. It involves collecting, analyzing, and sharing information related to malicious activities such as malware attacks, phishing campaigns, and vulnerability exploitation.

In a college environment, threat intelligence can help the IT team understand the types of attacks that commonly target educational institutions. By using threat intelligence feeds, the SOC team can update firewall rules, block malicious IP addresses, and strengthen system security. Threat intelligence also helps in predicting potential attacks and preparing preventive measures, ensuring that the college network remains protected from external cyber threats.

Incident Response (Extended)

Incident response is a structured approach used to handle cybersecurity incidents efficiently. The process usually includes several stages such as **detection, analysis, containment, eradication, and recovery**. When a security alert is generated, the SOC team first analyzes the event to determine whether it is a real threat or a false alarm.

If the incident is confirmed, the affected systems are isolated to prevent the threat from spreading across the network. After containment, the security team removes the malicious elements such as malware or unauthorized access points. Finally, the systems are restored to normal operation and security improvements are implemented. Proper incident response ensures that cyber incidents are handled quickly and that the college network remains secure and operational.

IBM QRadar – Understanding About the Tool (Extended)

IBM QRadar is a widely used **SIEM tool** designed to detect and analyze security threats across an organization's IT infrastructure. It collects log and event data from various sources including servers, network devices, applications, and security tools. QRadar uses advanced analytics and correlation rules to identify suspicious patterns that may indicate cyber attacks.

The tool provides a centralized dashboard where security analysts can monitor network activities and investigate alerts. QRadar also prioritizes security incidents based on their

severity, allowing analysts to focus on the most critical threats first. In a college SOC environment, QRadar can help track unauthorized login attempts, detect malware activity, and monitor network traffic. This improves the ability of the IT team to quickly identify and respond to potential security threats.

Conclusion

Stage 1: What You Understand from Web Application Testing

From web application testing, we understand that web applications may contain different security vulnerabilities that attackers can exploit. Testing helps identify weaknesses such as **cross-site scripting, SQL injection, broken authentication, and access control issues**. By performing web application security testing, we can detect these vulnerabilities early and apply proper security measures to protect sensitive data. This process also improves the overall reliability and security of the application by ensuring that user inputs, authentication mechanisms, and data handling are properly secured.

Stage 2: What You Understand from the Nessus Report

From the Nessus report, we understand how vulnerability scanning tools can identify security issues present in systems, servers, and applications. The report provides detailed information about detected vulnerabilities along with their **severity levels such as low, medium, or high**. It also explains the potential impact of these vulnerabilities and suggests mitigation strategies to fix them. By analyzing the Nessus report, we can prioritize critical vulnerabilities and apply necessary security patches or configuration changes to strengthen the security of the system.

Stage 3: What You Understand from SOC / SIEM / IBM QRadar Dashboard

From the SOC, SIEM, and QRadar dashboard, we understand how organizations monitor security events in real time. These platforms collect logs and security data from different systems and analyze them to detect suspicious activities or potential cyber attacks. The dashboard provides visual insights, alerts, and reports that help security analysts quickly identify threats and respond to incidents. This centralized monitoring improves the ability to detect attacks early, investigate security events, and protect the organization’s network and data from cyber threats.

Future Scope

Stage 1: Future Scope of Web Application Testing

The future scope of web application testing is very significant as web applications continue to grow in complexity and usage. With the increasing use of cloud platforms, mobile applications, and online services, web application security testing will become more advanced and automated. Future testing methods will involve artificial intelligence and machine learning to detect vulnerabilities faster and more accurately. Automated security testing tools will help developers identify security flaws during the development phase itself, reducing the risk of cyber attacks. Continuous security testing will also become an important part of the software development lifecycle to ensure that web applications remain secure against evolving threats.

Stage 2: Future Scope of the Testing Process You Understood

The testing process will continue to evolve with the advancement of technology and cybersecurity practices. In the future, organizations will focus more on **automated vulnerability scanning, continuous monitoring, and real-time security assessments**. Security testing will be integrated directly into development environments using DevSecOps practices, ensuring that security is considered at every stage of application development. Advanced testing frameworks will also help identify complex vulnerabilities and reduce manual effort. This will lead to faster detection of security issues, improved system reliability, and stronger protection of sensitive data.

Stage 3: Future Scope of SOC / SIEM

The future scope of **SOC and SIEM** systems will focus on improved threat detection, automation, and faster incident response. Modern SOC environments will use advanced technologies such as artificial intelligence, behavioral analytics, and threat intelligence to identify sophisticated cyber attacks. SIEM platforms will become more scalable and capable of analyzing large volumes of security data in real time. Automated incident response mechanisms will help security teams react quickly to potential threats and reduce response time. These advancements will strengthen cybersecurity defenses and help organizations maintain secure IT environments in the future.

Topics Explored

During this project, several important cybersecurity concepts were explored to understand how organizations secure internal applications using modern security frameworks. These topics helped in learning how to protect enterprise resources through controlled access and continuous monitoring.

- Context-Aware Access Control
- Identity-Based Authentication and Authorization
- Device Posture and Endpoint Security Validation
- Location-Based Access Control
- Application Risk Evaluation and Policy Enforcement
- Zero Trust Network Access (ZTNA) Architecture
- Application-Specific Access Policies
- Vulnerability Assessment and Security Testing
- Security Operations Center (SOC) Monitoring
- Security Information and Event Management (SIEM)
- Threat Intelligence and Incident Response

Tools Explored

Several cybersecurity tools and platforms were studied during the completion of this project. These tools help in identifying vulnerabilities, monitoring security events, and ensuring secure access to enterprise applications.

- Nessus – Used for vulnerability scanning to identify security weaknesses in systems and applications.
- IBM QRadar – Used for monitoring security logs, detecting suspicious activities, and analyzing network events.
- MISP – Used for sharing and analyzing cyber threat intelligence.
- Zscaler Private Access – Used to implement Zero Trust Network Access and application-level secure access policies.